Programación Segura (17 Semanas)

CRONOGRAMA				
Semana	Inicio	Fin	Unidad	Tema/s
1	18-Aug	21-Aug	Inicio	Programa. Presentación de la Materia. Cronograma.
2	24-Aug	28-Aug	1	Introducción a la Seguridad en el Software y DevSecOps
3	31-Aug	04-Sep	1	Arquitectura Zero Trust y Marcos Corporativos (MSSDL)
4	07-Sep	11-Sep	2	El Universo OWASP y Gestión de Vulnerabilidades + Controles Proactivos y Defensa en Profundidad
5	14-Sep	18-Sep	3	Fundamentos del Modelado y Metodología VAST
6	21-Sep	25-Sep	3	Metodología PASTA (Proceso Completo)
7	28-Sep	02-Oct	Examen	Primer Parcial
8	05-Oct	09-Oct	Examen	Primer Parcial
9	12-Oct	16-Oct	4	El Modelo STRIDE (S, T, R) + El Modelo STRIDE (I, D, E) y Metodología TRIKE
10	19-Oct	23-Oct	5	Clasificación Cualitativa (DREAD) y Framework CVSS v4.0
11	26-Oct	30-Oct	5	CVSS v4.0 Avanzado, OCTAVE y Enfoques Híbridos (QTMM)
12	02-Nov	06-Nov	6	Framework MITRE ATT&CK (La Perspectiva del Adversario)
13	09-Nov	13-Nov	6	Automatización Integral y Gobernanza DevSecOps
14	16-Nov	20-Nov	Examen	Segundo Parcial
15	23-Nov	27-Nov	Examen	Recuperatorio
16	30-Nov	04-Dec	Cierre	Cierre
17	09-Dec	15-Dec	Mesa de examen Final	

24.08 - 04.09 – Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

Semana 2: Introducción a la Seguridad en el Software y DevSecOps

- Fundamentos de Seguridad en el Software: El costo de la inseguridad y por qué falla el software.
- Evolución del SDLC tradicional con seguridad hacia metodologías ágiles y DevSecOps.
- Filosofía y pilares de DevSecOps: Cultura, Automatización, Medición y Compartición (CAMS). La seguridad como un proceso continuo.

Semana 3: Arquitectura Zero Trust y Marcos Corporativos (MSSDL)

- Arquitectura y Gobernación de Confianza Cero (Zero Trust): Verificación explícita, acceso de menor privilegio y asunción de brecha (*assume breach*). Aplicación a nivel de código y APIs.
- Marcos institucionales: El ciclo MSSDL (Microsoft Security Development Lifecycle).
- Análisis teórico de las fases obligatorias del MSSDL: Requerimientos, Diseño, Codificación, Verificación, Lanzamiento y Respuesta.

07.09 - 11.09 – Bloque 2: Ecosistema OWASP y Protección Proactiva

Semana 4: El Universo OWASP y Gestión de Vulnerabilidades, Controles Proactivos y Defensa en Profundidad

- Proyectos, aplicaciones y protocolos dedicados a determinar y combatir las causas que hacen que el software sea inseguro.

- La comunidad colaborativa OWASP: Filosofía, estructura y recursos gratuitos globales.
- Protección proactiva de OWASP: Teoría sobre la defensa en profundidad, validación de entradas, codificación de salidas y manejo seguro de datos.
- Gestión de la identidad, autenticación y criptografía desde la perspectiva del desarrollo seguro.

14.09 - 25.09 – Bloque 3: Metodologías de Modelado de Amenazas (Threat Modeling)

- **Semana 5: Fundamentos del Modelado y Metodología VAST**
    - Modelado de amenazas: Metodologías existentes que garantizan la programación segura mediante la identificación de vulnerabilidades.
    - Modelo de amenaza de aplicación (perspectiva de desarrollo/arquitectura) vs. Modelo de amenaza operacional (perspectiva de infraestructura).
    - Introducción a VAST (Visual, Agile, and Simple Threat modeling): Pilares teóricos e integración en flujos ágiles.
- **Semana 6: Metodología PASTA (Proceso Completo)**
    - Introducción a PASTA (Process for Attack Simulation and Threat Analysis) como marco orientado al riesgo del negocio.
    - **Fase 1:** Definición de objetivos comerciales y de negocio.
    - **Fase 2:** Definición de alcance técnico (Superficie de ataque y dependencias).
    - **Fase 3:** Descomposición de la aplicación (Flujos de datos y fronteras de confianza).
    - **Fase 4:** Analizar amenazas (Inteligencia de amenazas y agentes).
    - **Fase 5:** Análisis de vulnerabilidades (Debilidades en diseño y código).
    - **Fase 6:** Análisis de ataque (Árboles de ataque y vectores de explotación).
    - **Fase 7:** Análisis de riesgo e impacto (Impacto financiero y operativo).

12.10 - 16.10 Bloque 4: Taxonomía de Amenazas (STRIDE) y Modelos Alternativos

- **Semana 9: El Modelo STRIDE (S, T, R), El Modelo STRIDE (I, D, E) y Metodología TRIKE**
    - Introducción a STRIDE y su relación con las propiedades de la información (CIA Triad + AAA).
    - **S**uplantación / Engaño (Spoofing).
    - **T**ampering / Contaminación (Alteración de datos).
    - **R**epudio (Repudiation): Trazas de auditoría y registros (*logs*) seguros.
    - **I**nformación (Information Disclosure / Difusión de información).
    - **D**enial of Service (Negación de servicio).
    - **E**levation of Privilege (Elevación de privilegio).

    - Metodología TRIKE: Identificando activos y definiendo requerimientos, creando diagramas de flujo de datos, identificando y mitigando amenazas y riesgos, validando el modelo.

19.10 - 30.10 - Bloque 5: Cuantificación del Riesgo y Métricas de Severidad

- **Semana 10: Clasificación Cualitativa (DREAD) y Framework CVSS v4.0**
    - Metodología DREAD: Potencial de daño, Reproductibilidad, Explotabilidad, Usuarios afectados y Descubribilidad.
    - Introducción a CVSS (Common Vulnerability Scoring System): Historia y evolución.
    - Métricas de base (Base Metrics) y la Escala cualitativa de severidad de la puntuación CVSS v.4.0.
- **Semana 11: CVSS v4.0 Avanzado, OCTAVE y Enfoques Híbridos (QTMM)**
    - Anatomía de la Cadena de vector (Vector String) y análisis de Métricas de amenaza, Métricas de ambiente y Métricas suplementarias en CVSS v4.0.
    - Metodología OCTAVE: Fase 1 (Construir perfiles de activos basados en la amenaza), Fase 2 (Identificar vulnerabilidades de infraestructura) y Fase 3 (Desarrollar planes y estrategias de seguridad).
    - QTMM (Quantitative Threat Modeling Method): Metodología híbrida que confluye STRIDE, árboles de ataque y CVSS.

02.11 - 13.11 Bloque 6: Tácticas de Ataque y Automatización en el Ciclo de Vida

- **Semana 12: Framework MITRE ATT&CK (La Perspectiva del Adversario)**
    - Introducción a MITRE ATT&CK como modelo basado en el comportamiento real del atacante.
    - Análisis teórico de la cadena de tácticas: Reconocimiento, Desarrollo de recursos, Acceso inicial, Ejecución, Persistencia, Escalamiento de privilegios, Evasión de defensa, Acceso de credenciales, Descubrimiento, Movimiento lateral, Recolección, Comando y control, Exfiltración e Impacto. Mapeo de mitigaciones desde el código.
- **Semana 13: Automatización Integral y Gobernanza DevSecOps**
    - Automatización integral de la seguridad: Conceptos y arquitectura de herramientas SAST, DAST y SCA en pipelines de CI/CD.
    - Colaboración interdepartamental, gobernanza de seguridad de software y el rol de los *Security Champions*. Síntesis final del curso.